Cybersecurity by Design for Critical Infrastructures

Laurea Magistrale in Informatica

alma.pennacchi@uniroma2.it

Marzo 2026

TOR VERGATA
UNIVERSITÀ DEGLI STUDI DI ROMA

Roadmap

1 From Observability to Decision

2 Laboratorio 2

Lezione 2 — Obiettivo

Domanda guida

Una volta osservata e modellata un'infrastruttura, come decidiamo che un comportamento sia **normale**, **anomalo**, **malevolo** o **non ancora classificabile**?

- definire la **normalità** in un sistema complesso
- misurare **deviazioni** in presenza di incertezza
- distinguere **anomalia**, **guasto**, **attacco**, **drift**

Dal modello alla decisione

Osservazione $\rightarrow$ Rappresentazione $\rightarrow$ Baseline $\rightarrow$ Deviazione $\rightarrow$ Decisione

Punto chiave

Il problema non è solo *vedere* un evento. Il problema è decidere se quell'evento sia compatibile con il comportamento atteso del sistema.

Comportamento

Definizione

Data una infrastruttura definita come un insieme di nodi di elaborazione di informazioni in grado di ricevere e trasmettere Ad ogni nodo, ad un certo istante di tempo, è associato uno stato. Un comportamento è l'insieme delle variazioni di stato dell'infrastruttura in un determinato intervallo di tempo e dei relativi flussi informativi verificatosi fra ogni possibile coppia di nodi.

- Chiusura transitiva di un grafo pesato in nodi e archi dove i pesi cambiano ad ogni istante di tempo. Lo chiamiamo Configurazione.

La normalità non è un punto

Idea

In una infrastruttura critica la normalità non coincide con un singolo valore, ma con una **regione di comportamenti ammessi**.

- il traffico notturno non coincide con quello diurno
- una finestra di manutenzione cambia i pattern ammessi
- un'emergenza clinica può alterare volumi e sequenze

Operating Envelope

Definition (Operating Envelope)

Insieme delle condizioni operative compatibili con il comportamento atteso del sistema.

- range di volumi
- latenze ammissibili
- sequenze consentite
- relazioni topologiche attese

Conseguenza

Un evento non è anomalo perché "diverso dalla media", ma perché **esce dall'inviluppo operativo ammesso**.

Baseline come insieme ammissibile

Sia $\mathcal{X}$ Insieme di tutte le configurazioni osservabili che può assumere una infrastruttura (lo spazio dei comportamenti osservabili).

Baseline

$$B = \{x \in \mathcal{X} : x \text{ è compatibile con il comportamento atteso}\}$$

Allora:

$$x \notin B \Rightarrow \text{deviazione}$$

Attenzione

Nella pratica B non è noto esattamente: viene **stimato** da dati, regole, vincoli operativi e contesto.

Baseline multidimensionale

La baseline non è una sola.

- **temporale**: quando avvengono gli eventi
- **topologica**: chi comunica con chi
- **volumetrica**: quanto traffico passa
- **frequenziale**: con che periodicità
- **sequenziale**: in quale ordine avvengono le azioni
- **di stato**: quali transizioni sono consentite

Baseline temporale

- backup notturni
- login concentrati in certe fasce orarie
- sincronizzazioni periodiche
- traffico ridotto nei weekend

Esempio

Un picco alle 03:00 può essere perfettamente normale se coincide con una procedura schedulata.

Baseline topologica

- HMI $\rightarrow$ PLC
- SCADA $\rightarrow$ Historian
- VPN $\rightarrow$ Gateway
- DMZ $\rightarrow$ OT tramite conduit definito

Esempio

Se compare una comunicazione `PLC` $\rightarrow$ `Internet`, la deviazione è topologica prima ancora che volumetrica.

Baseline sequenziale

Non conta solo *cosa* avviene, ma *in quale ordine*.

- autenticazione $\rightarrow$ autorizzazione $\rightarrow$ accesso
- lettura stato $\rightarrow$ comando $\rightarrow$ conferma
- update $\rightarrow$ restart $\rightarrow$ sync

Idea

Due eventi leciti, in sequenza sbagliata, possono costituire una deviazione.

Baseline di stato

Un'infrastruttura evolve tra stati.

$$\text{idle} \rightarrow \text{active} \rightarrow \text{maintenance} \rightarrow \text{recovery}$$

- alcune transizioni sono attese
- altre sono rare
- altre ancora non dovrebbero mai avvenire

Interpretazione

L'anomalia può essere una **transizione di stato illegittima**.

Deviazione: concetto operativo

Definizione

La deviazione è la misura della distanza tra il comportamento osservato e la regione di comportamento atteso.

$$d(x, B) \rightarrow \text{score di deviazione}$$

- score basso: variazione compatibile
- score intermedio: comportamento da indagare
- score alto: probabile rottura della baseline

Stato reale vs stato osservato

Non osserviamo mai direttamente il sistema completo.

Formalizzazione

$$y(t) = O(x(t))$$

dove:

- $x(t)$ = stato reale del sistema
- $y(t)$ = stato osservato
- O = operatore di osservazione

Conseguenza

Detection = decisione presa su osservazioni **parziali** e **imperfette**.

Osservazione parziale e rumore

Una deviazione osservata può dipendere da:

- rumore di misura
- perdita di log
- campionamento incompleto
- telemetria distorta
- contesto mancante

Messaggio

Un sistema di detection non vede la realtà: vede una **proiezione** della realtà.

Anomalia non significa attacco

$$\text{anomalia} \neq \text{attacco}$$

Una deviazione può essere:

- **guasto**
- **degrado**
- **misconfigurazione**
- **manutenzione**
- **attacco**
- **unknown**

Decisione sotto incertezza

Problema

Non dobbiamo solo rilevare una deviazione. Dobbiamo decidere se essa giustifica una reazione.

$$\text{decisione} = f(\text{score}, \text{contesto}, \text{rischio}, \text{costo})$$

- stesso score, decisioni diverse in contesti diversi
- la soglia non è solo statistica: è anche operativa

Falsi positivi e falsi negativi

Falso positivo

Segnalo come anomalo un comportamento che in realtà è compatibile con la baseline.

Falso negativo

Considero normale un comportamento che in realtà è malevolo o pericoloso.

Infrastrutture critiche

I costi dei due errori non sono simmetrici.

Asimmetria dei costi

- in un social network un falso positivo è fastidioso
- in un ospedale un falso positivo può rallentare l'operatività
- in un sistema OT un falso negativo può produrre impatti fisici

Conseguenza

La taratura delle soglie è un problema di **risk engineering**, non solo di statistica.

Entropia operativa

Idea

L'entropia misura il grado di dispersione o imprevedibilità di una distribuzione osservata.

$$H(X) = -\sum_i p(x_i) \log p(x_i)$$

- entropia bassa: comportamento regolare e ripetitivo
- entropia alta: comportamento più vario e meno prevedibile

Entropia dei flussi

Possibili misure:

- entropia delle sorgenti
- entropia delle destinazioni
- entropia dei protocolli
- entropia delle porte
- entropia delle sequenze temporali

Esempio

Una scansione laterale aumenta spesso l'entropia delle destinazioni e delle porte.

Stabilità e complessità

Punto importante

Non tutta l'entropia è cattiva.

- un sistema troppo rigido può essere fragile
- un sistema troppo variabile può essere ingestibile

Obiettivo

Definire una **complessità operativa accettabile**, non inseguire la rigidità assoluta.

Outlier, Drift, Regime Shift

Non tutte le deviazioni hanno la stessa natura.

- **outlier**: punto isolato anomalo
- **drift**: cambiamento graduale della distribuzione
- **regime shift**: passaggio a un nuovo comportamento strutturale

Implicazione

Un outlier può essere ignorabile; un regime shift quasi mai.

Change Detection

Obiettivo

Rilevare non solo eventi anomali, ma cambiamenti persistenti nel comportamento del sistema.

- cambiamenti di media
- cambiamenti di varianza
- cambiamenti di topologia
- cambiamenti di sequenza

Dallo score alla classificazione preliminare

Una possibile pipeline:

1. acquisizione osservabili
2. estrazione feature
3. confronto con baseline
4. calcolo score di deviazione
5. classificazione preliminare
6. escalation o contromisura

Nota

La classificazione iniziale può rimanere `unknown`: è una decisione corretta quando l'evidenza è insufficiente.

Messaggio finale della teoria

Idea centrale

La cybersecurity per infrastrutture critiche non è solo anomaly detection.

È **decisione sotto incertezza** su sistemi osservati solo parzialmente.

Roadmap

1 From Observability to Decision

2 Laboratorio 2

Lab 2 — From Model to Baseline

Obiettivo

Riprendere il modello costruito nel Laboratorio 1 e usarlo per definire una **baseline comportamentale**, così da valutare se una nuova finestra osservata sia **compatibile**, **deviata** o **critica**.

- il sistema è lo stesso del Lab 1
- il punto di partenza è il vostro modello
- il nuovo compito è: **definire la normalità**

Step 2

Per almeno 5 relazioni significative, compilare:

Relazione	Normale	Quando	Intensità attesa	Note

- **Quando**: giorno / notte / manutenzione / sempre / mai
- **Intensità**: bassa / media / alta

Esempio di baseline qualitativa

Relazione	**Normale**	**Quando**	**Intensità**	**Note**
VPN $\rightarrow$ EHR	sì	giorno	media	accesso remoto medici
EHR $\rightarrow$ DB	sì	sempre	alta	backend applicativo
EHR $\rightarrow$ Backup	sì	notte	alta	backup schedulato
GuestWiFi $\rightarrow$ EHR	no	mai	nulla	deviazione topologica
Device1 $\rightarrow$ DB	no	mai	nulla	percorso non previsto

Step 3 — Finestra osservata

Dopo aver definito la baseline, ogni gruppo riceve una finestra osservata con eventi come:

- aumento di retry
- nuovo nodo osservato
- traffico notturno inatteso
- relazione topologica non prevista
- picco volumetrico

Compito

Non dovete cercare "l'attacco" in astratto. Dovete confrontare l'osservato con la baseline che avete costruito.

Dataset osservato

Time	Source	Dest	Proto	Pkts	Status
08:10	VPN	EHR	TLS	145	ok
08:11	EHR	DB	TCP	240	ok
08:12	Device1	EHR	TLS	62	ok
08:13	Device2	EHR	TLS	59	ok
08:14	EHR	BookingCloud	HTTPS	95	ok
08:16	GuestWiFi	EHR	TCP	18	ok
08:17	UnknownHost	EHR	TCP	27	fail
08:18	VPN	EHR	TLS	310	retry
08:19	EHR	DB	TCP	520	ok
08:20	Device1	DB	TCP	44	ok
02:05	EHR	Backup	TCP	980	ok
02:07	Backup	EHR	TCP	155	ok
02:09	VPN	EHR	TLS	88	ok
02:10	EHR	BookingCloud	HTTPS	140	ok
02:11	DB	UnknownHost	TCP	160	ok

Step 4 — Valutazione delle deviazioni

Per ogni evento osservato, dovete chiedervi:

1. È compatibile con la baseline?
2. La deviazione è **lieve**, **media** o **forte**?
3. La causa più plausibile è:
   - fault
   - manutenzione
   - attacco
   - unknown
4. Quale dato aggiuntivo servirebbe per decidere meglio?

Step 5 — Output richiesto

Ogni gruppo consegna una tabella finale:

Evento	Compatibile?	Score	Classificazione	Dato utile

Nota

Il punto non è solo etichettare un evento, ma giustificare la classificazione.

Criterio di ragionamento

Una possibile logica:

1. relazione attesa o inattesa?
2. fascia oraria coerente o incoerente?
3. intensità dentro o fuori baseline?
4. stato normale, retry o fail?
5. manca contesto per classificare?

Importante

`unknown` non è un errore: è una classificazione corretta quando l'evidenza è insufficiente.

Debrief finale

Domande da discutere:

1. quale deviazione è più grave?
2. quale è più ambigua?
3. quale richiede risposta immediata?
4. in quali casi la risposta corretta è `unknown`?

Messaggio finale

Detection non significa indovinare attacchi. Significa ridurre l'incertezza fino a una decisione difendibile.